Joiner, Mover, Leaver

Project: *Okta Identity Lab |* ***Author:*** *Ismayeel Khan |* ***Date:*** *October 21, 2026 |* ***Environment:*** *Okta Integrator Free Plan*

---

1. Goal

The goal of this checkpoint was to run the full life cycle of an employee in Okta: a new hire joins, someone changes teams, and someone leaves.

2. Why the Life Cycle Matters

People do not stay the same in a company, and their access should not stay the same either. Getting this right is a big part of real IAM work, because old access that nobody removes is how security problems start.

Event	What it means	What access should do
Joiner	A new employee starts	Get the access their role needs, and nothing more
Mover	An employee changes teams	Lose the old team's access and gain the new team's access
Leaver	An employee leaves	Lose all access immediately, while the record is kept for audits

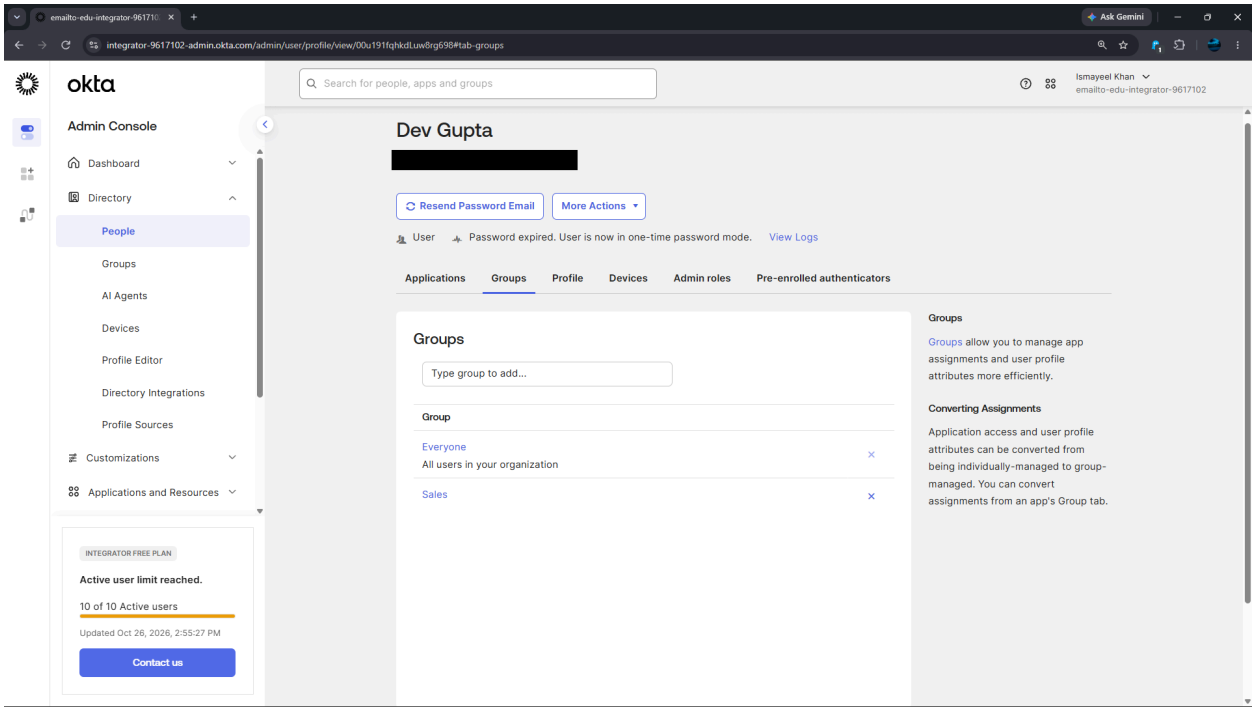
3. The Plan and the Order

My free plan allows only 10 active users, and all 10 slots were already used. A new hire needs a free slot, so I did the steps in this order:

1. **Leaver** first: deactivate one user to free a slot.
2. **Joiner** second: use that slot for a new hire.
3. **Mover** last: move an existing user to a different team.

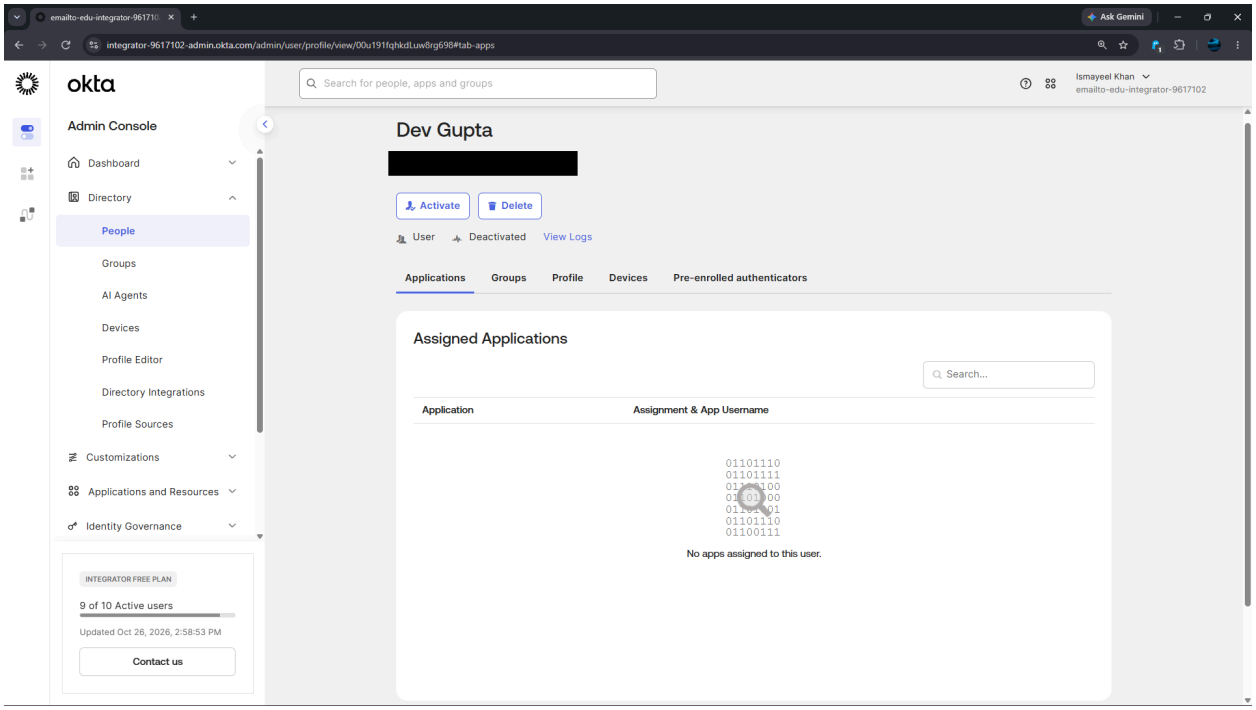
4. Leaver: Deactivating Dev Gupta

Dev Gupta is a Sales Rep. Before changing anything, I recorded his starting state: he was a member of the **Sales** group (plus the built-in Everyone group), so he had the apps assigned to Sales.



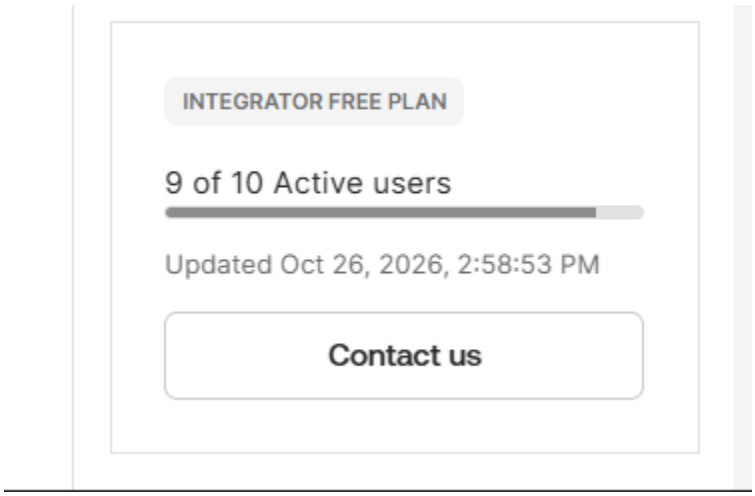
Before: Dev Gupta's groups, Everyone and Sales.

I then deactivated his account. His profile now shows the status **Deactivated**, and the list of assigned apps is empty. Okta offers **Activate** and **Delete** buttons for a deactivated user.



After: Dev Gupta is deactivated and has no apps assigned.

The user counter dropped from 10 to **9 of 10**, so deactivating a user frees a slot on the free plan.



Counter showing 9 of 10 active users after the deactivation.

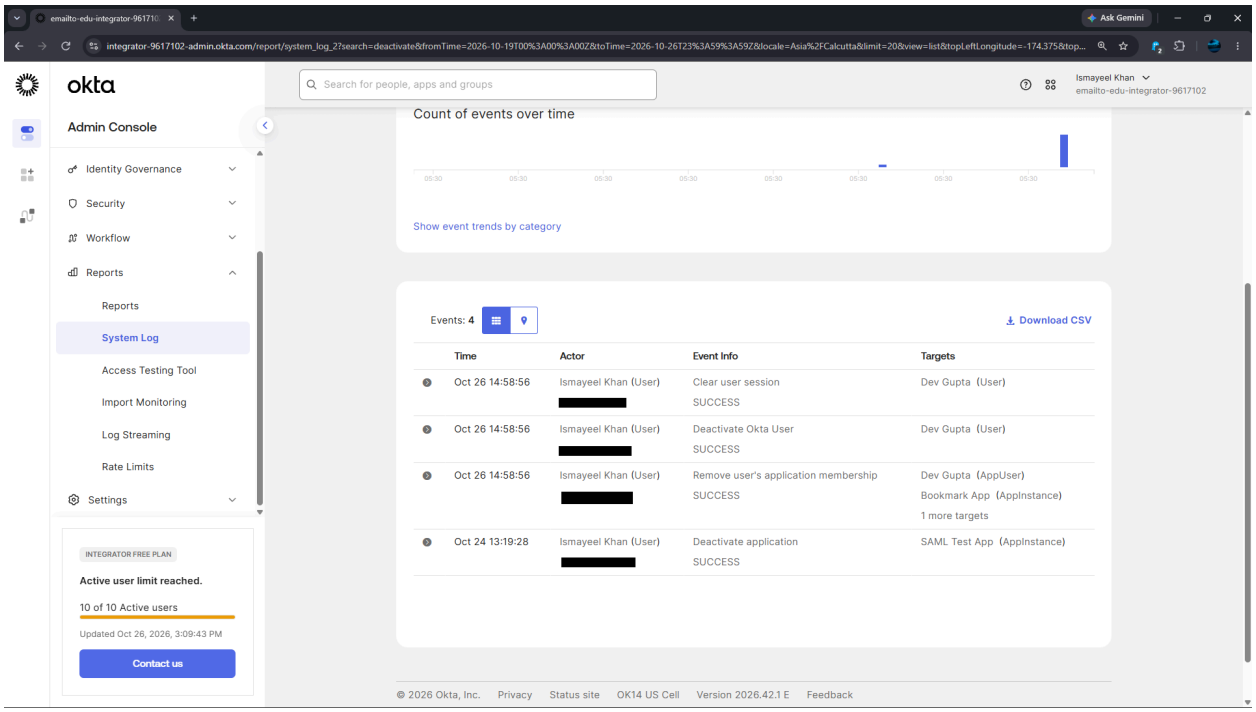
Why deactivate instead of delete? Deactivating blocks sign-in right away and keeps the account's history, which companies may need for audits. Deleting removes the record. In real companies, deletion usually happens much later, if at all.

What the System Log recorded

I searched the System Log for the deactivation. It recorded three actions in the same second:

- **Remove user's application membership** (Dev's access to the Bookmark App was taken away)
- **Deactivate Okta user**
- **Clear user session** (any open sign-in was ended)

The older entry below them is unrelated to Dev. It is an earlier change I made to a test app.



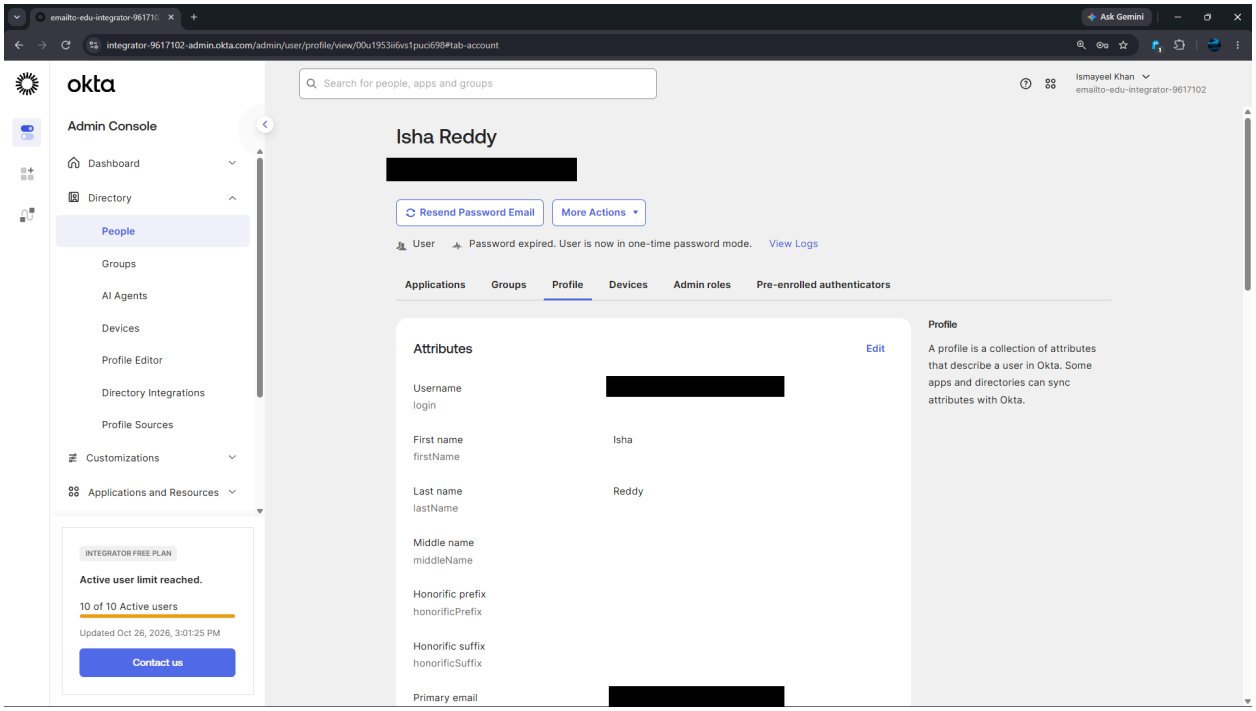
System Log showing Dev Gupta's deactivation, app removal, and session clear. (IP addresses blacked out.)

5. Joiner: Onboarding Isha Reddy

With a slot free, I added a new HR employee, **Isha Reddy**:

- Created her account with an email-style username
- Placed her in the **HR** group, so she receives the access that group gets
- Set a temporary password and turned on **"User must change password on first login"**
- Filled in her department and job title on her profile

Her status shows **Password expired**, which is normal for a new account until she signs in for the first time and chooses her own password. The counter went back to **10 of 10**.



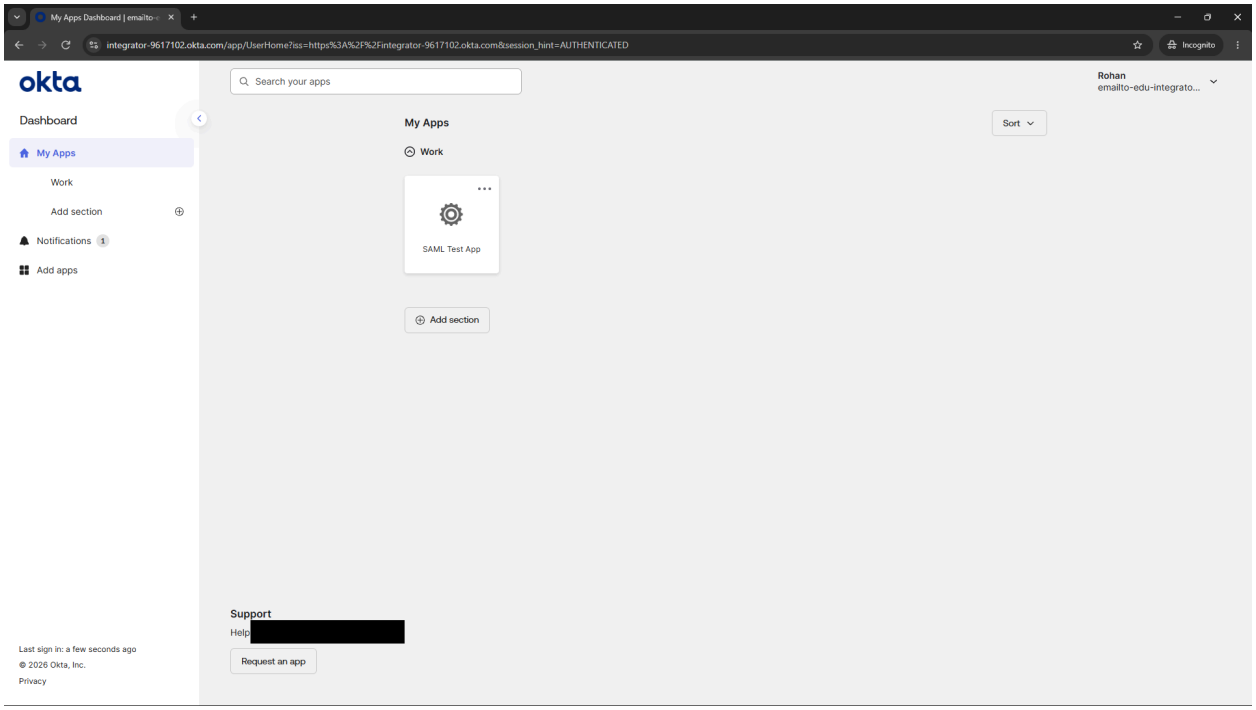
Isha Reddy's profile after onboarding. The counter is back to 10 of 10.

6. Mover: Moving Rohan Mehta from IT to Sales

Rohan Mehta was an IT Support Engineer. I moved him to Sales by making three changes:

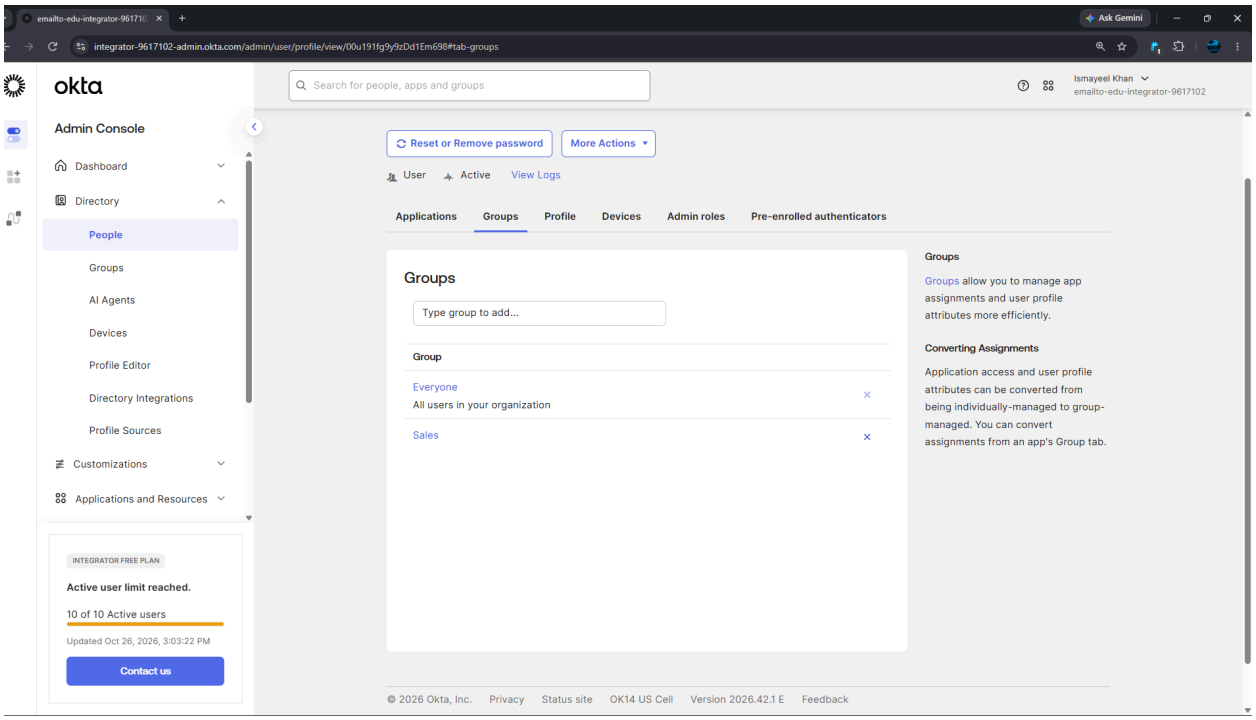
- Changed his **department** to Sales and his **title** to Sales Engineer
- **Removed** him from the IT group
- **Added** him to the Sales group

Before the move, Rohan's dashboard showed the **SAML Test App**, because that app is assigned to IT. This is the same screenshot from Document 3.



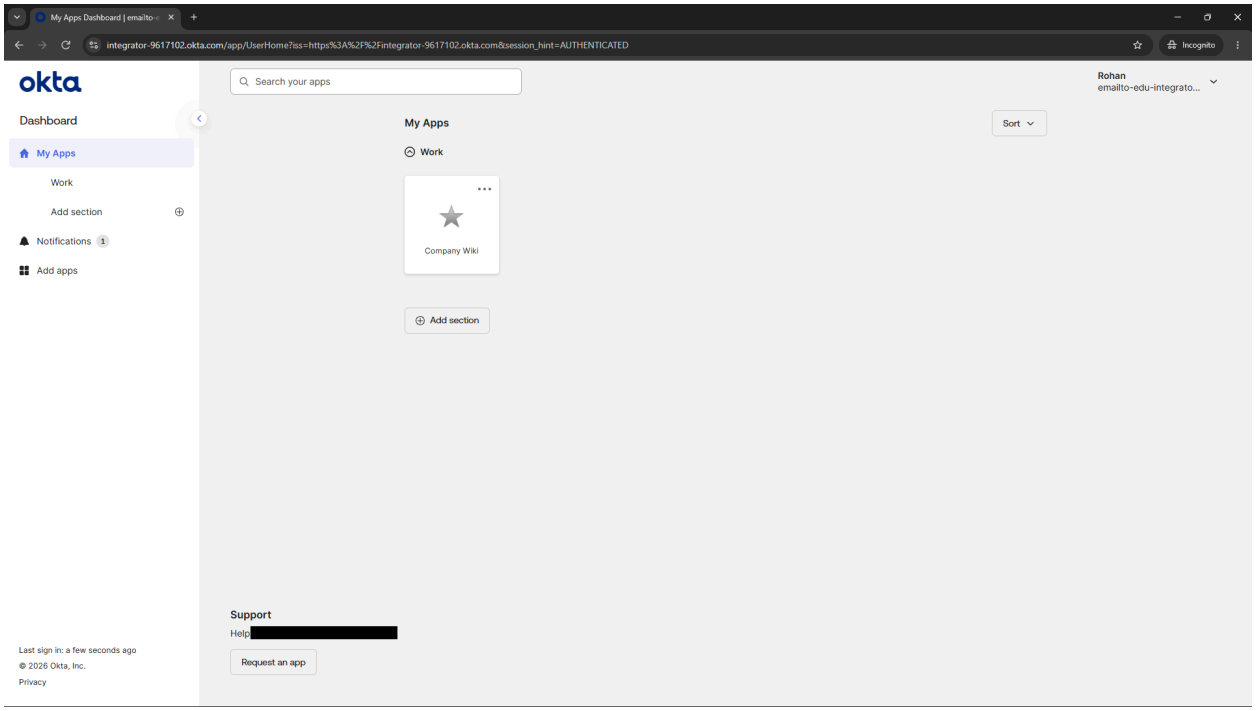
Before: Rohan's dashboard as an IT user.

After the change, his groups are Everyone and **Sales**.



Caption: After: Rohan's groups, Everyone and Sales.

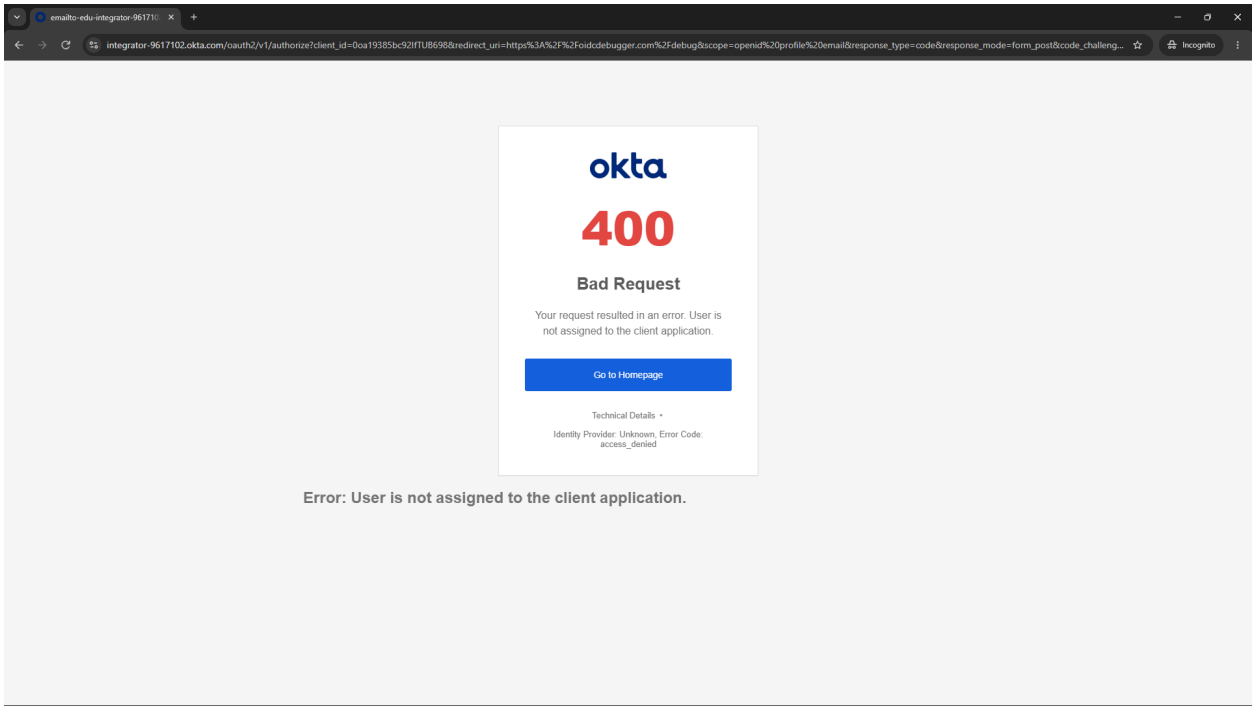
When I signed in as Rohan again, his dashboard had changed. He no longer sees the SAML Test App, and he now sees the Company Wiki, which is assigned to Sales. Nothing was changed on the apps themselves, only on the user.



After: Rohan's dashboard now shows the Company Wiki.

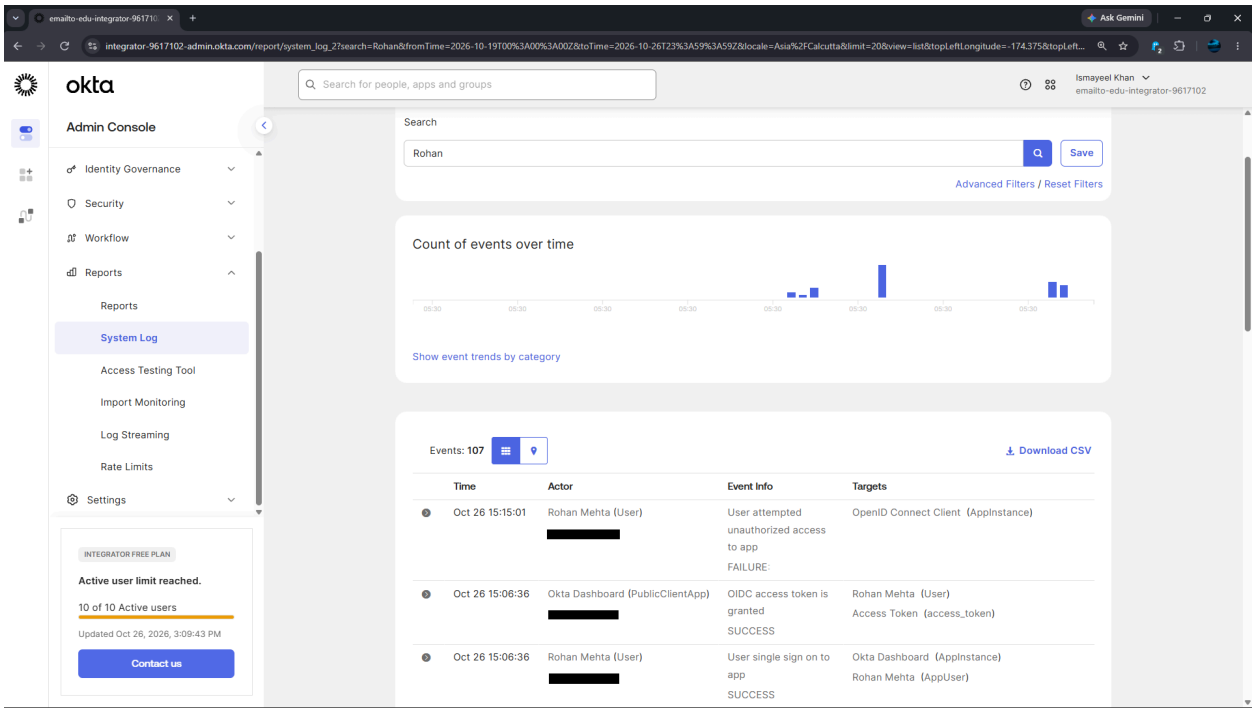
Proving the old access is really gone

To check that his IT access was removed and not just hidden, I tried to sign Rohan in to the IT-only OIDC Test App from Checkpoint 3. Okta blocked him with **400 Bad Request: "User is not assigned to the client application."** A few days earlier, the same sign-in had worked for him.



Rohan is now blocked from the IT-only app.

The System Log shows the same result as **"User attempted unauthorized access to app,"** with the result **FAILURE**.



System Log entry for Rohan's blocked attempt. (IP addresses blacked out.)

7. Notes and Things I Noticed

- **Doing the leaver first mattered.** With the free plan's 10-user cap, I could not have added the new hire without freeing a slot.
- **The counter can lag.** After changes, I refreshed the page before trusting the number.
- **Access changes follow the group.** I never edited an app to move Rohan. I only changed his groups.
- **In a real company**, a leaver's access would be removed on their last day, ideally the same hour, with approval from their manager or HR. A mover's old access should be removed when the move happens, not left in place.

8. Key Concepts I Learned

- **Joiner, mover, leaver:** the three events that change who needs access.
- **Deactivate vs. delete:** deactivating blocks access and keeps the record. Deleting removes it.
- **Access follows the group:** moving a user between groups changes their apps automatically.
- **Old access is a risk:** movers who keep old permissions are a common cause of security problems.
- **Log evidence:** the System Log shows exactly when an account was deactivated and what was removed.

9. Limits and Notes

- The free plan allows 10 active users, which shaped the order of the steps.
- New users have not signed in yet, so their status stays "Password expired."
- I did the changes by hand. Larger companies often automate these steps from an HR system.
- All users and data are fake.

10. What I Learned and What Is Next

The main lesson from this checkpoint: **access should follow the person's role, and it should be removed when the role ends.**

Next, in Checkpoint 6, I act as the helpdesk: I break things on purpose, then find the cause in the System Log and fix them.